

IDENTITY PROVIDER	
Issues short-lived agent credentials · no persistent tokens in agent context	
AGENT · agent_id: acct-analyst · scope: read: reports	
✓ PERMITTED ACTIONS read: analytics_reports write: draft_summaries call: summarization_api read: public_schemas scoped · expiring · audited	✗ DENIED ACTIONS write: production_db delete: any_record read: pii_tables call: payment_api hard-deny · no escalation path
HUMAN APPROVAL GATE	
triggered when scope boundary approached	

Table 3: Agent identity and least-privilege authorisation model

The principle is least-privilege at the agent scope level: task-scoped credentials, short-lived tokens, and hard deny lists with no escalation path. If an agent needs broader permissions to complete a task, it should escalate to a human — not acquire permissions silently while nobody’s watching.

Multi-agent trust boundaries: When agents call other agents, as they increasingly do in mesh architectures, the trust model gets interesting. Agent A invoking Agent B is not the same as a service calling another service. The calling agent may be carrying injected instructions, acting on corrupted context, or operating outside its intended scope. Agent B cannot simply inherit the trust of the caller. In a well-designed system, it won’t.

Compliance, data residency and privacy: This one catches teams off guard more than any other. An agent that retrieves customer records, sends them to an LLM provider for analysis, writes outputs to a cloud store, and triggers a notification has just created four potential jurisdictional

ORCHESTRATOR		
verified identity · signed task token		
AGENT A	AGENT B	AGENT C
Research / Retrieval	Analysis / Reasoning	Action / Write
TRUST RULES - Agent-to-agent calls must carry a signed delegation token from the orchestrator, not the calling agent’s own credential - Receiving agent validates scope independently -- inherited trust is a vulnerability, not a feature. Every agent in a mesh should validate its own authorisation independently, treating messages from other agents with the same scepticism it would apply to an external API call.		

Table 4: Multi-agent trust boundary model

touchpoints, each with its own data residency, retention, and consent implications. Most teams only map this out after something goes wrong.

GDPR, HIPAA, and SOC 2 frameworks don’t yet provide direct guidance on autonomous agents. Until they do, the enterprise burden is to instrument each data movement in an agent workflow, classify the data at each step, and enforce residency constraints at the integration layer. Not as an afterthought post-deployment.

Pillar three

Governance at scale

Here’s something that often surprises teams: agents are not static software. Their behaviour is partially a function of model weights, prompt versions, tool schemas, and runtime context -- all of which can change independently. Governance at scale means treating every one of those variables as a versioned, managed artifact with defined change procedures, cost accountability, and behavioural test coverage. The urgency is real: *Deloitte’s 2025 Emerging Technology Trends* study found that while 38% of organisations are piloting agentic solutions, only 11% are actively running them in production. That gap points directly to unresolved governance, not unproven technology.

Cost controls and resource governance: An agentic workflow that loops unexpectedly for 40 iterations instead of 4 doesn’t just produce wrong output. It produces a surprisingly large invoice. LLM token costs, third-party API calls, and compute charges are all susceptible to unbounded growth when agents misbehave. Governance needs to happen at the workflow level, not just at the infrastructure level.

Testing and behavioural validation: Unit tests don’t map to agent behaviour. You can’t assert that a reasoning system returns the correct output for a given input — the space of inputs is unbounded, the outputs are probabilistic, and the path

LOW RISK		HIGH RISK
LOW COST	✓ STANDARD OPS Retrieval / read agents - standard rate limiting + cost attribution	⚠ MONITOR CLOSELY Reasoning-heavy decision loops - audit trail + confidence thresholds + HITL
HIGH COST	COST-ATTRIBUTE & ALERT Batch processing agents - quota + throttle + cost dashboard	🛑 HARD BUDGET CAP Multi-step writes workflows - per-run cap + kill switch + HITL gate

Table 5: Agentic cost governance framework